Chap 1

1. Five steps of ethical decision

- Develop problem statement // Critical security flaw in (department) , (problem)
- Identity alternatives // Escalate to higher management & Report externally
- Evaluate and choose Alternatives // Compare each option by risk, effectiveness, and cost
- Implement decisions // Execute the best choice.
- Evaluation results // check if the issue was resolved and what impact it had on users and company

2. Morals, Ethics, Law

Morals - Personal beliefs of right and wrong

Ethics - Rules or codes of conduct expected by a society, institution, or profession.

Law - A set of rules that determines what we are permitted or not permitted to do.

3.Common ethical issues for it users

- Software piracy is the unauthorised copying, distribution, or use of software without a valid license

Exp : In a workplace, IT professionals may be involved in software piracy either by actively installing unlicensed software.

- Inappropriate use of computing resources, means using company IT resources for personal use.

Exp : Examples include browsing unrelated websites or playing online games. // lowers work efficiency.

- Inappropriate sharing of information, means disclosing private or confidential data to unauthorized parties.

Exp : Private data includes employee records like salary, as well as customer details such as credit card number. / Sharing information will compromise individual privacy.

Chap 2

4. Two types of security attacks

Passive attacks 被动攻击
- Intercepts information without affecting system resources
- Focus is on prevention rather than detection because the system shows no signs of attack.

Exp : Attacker secretly monitors data transmission, such as eavesdropping.

Active attacks 主动攻击
- Modifies data stream or create false data to disrupt the system
- Harder to prevent, focus is on detection and recovery.

Exp : Attacker actively tampers with communication, such as altering messages.

5. Cybercrime

- Cybercrime is a form of illegal activity that takes place over the Internet. It refers to any criminal operation carried out using modern technology.

Exp : Illegal entry, illegal intrusion, and computer abuse

6. Hackers VS Crackers

Ethical hacker
- Authorised security professional who tests system vulnerabilities

Cracker
- Malicious hacker who breaks into systems illegally

7. Key threat actors

Malicious insider
- Employee who intentionally misuses authorised access

Cybercriminal
- Hacker motivated by financial gain

Hacktivist
- Uses hacking for political or social agendas

Cyber Terrorist
- Targets critical infrastructure to cause destruction and fear

Chap 6

8. Three type of CIA Triad

Confidentiality
- only authorised individuals can access sensitive information
Exp : Credit card numbers used online must be kept secret from unauthorized parties.

Integrity
- data remains accurate, complete, and unaltered
Exp : Ensuring no one tampers with order quantity sent from website to warehouse.

Availability
- Authorised users can access data when needed
Exp : Warehouse employees must be able to view total items ordered so correct goods can be shipped.

9. Three type of IT security policies

Information security policy
- High-level authority and guidance for the security program.
Exp : Sets overall direction for protecting company information security assets.

Incident response policy
- describes how to respond to security incidents
Exp : Step-by-step plan for handing breaches, such as who does what.

SDLC policy
- Integrates security at every stage of software development
Exp : Ensures security checks throughout design, coding, and testing.

10. Trustworthy Computing

- Computing that provides secure, private, and reliable interactions based on sound business practices.

Four pillars

- Security
// Protection from unauthorized access and attacks

- Privacy
// Control over how personal data is collected and used

- Reliability
// System performs consistently as expected

- Business integrity
// Company acts ethically and transparently with data

11. ISO 27001

- International standard providing requirements for an Information Security Management System (ISMS).

Exp : 14 control categories covering people process, and IT systems, such as access control, operation security, and asset management.

Chap 7

12. Software Development Methodologies

Agile
- Flexible & iterative approach
Exp : Breaks project into small increments // Teams adjust based on client feedback

Waterfall
- Traditional & linear approach
Exp : Each phase must finish before next starts // Suits projects with fixed, clear requirements

13. Software Testing Types

Black-box testing
- Testing without knowing internal code structure
Explain
- Treats software as a “block box”, tests input and expected output.
- Black-box checking is done without the tester knowing something about the code’s design.

White-box testing
- Testing with full knowledge of internal code logic
Explain
- Considers the software machine as a system with planned input and output behaviors and known internal workings

14. Software quality characteristics

Usability
- All users can easily invoke system features
Reusability
- Components can be reused for new applications
Maintainability
- Bugs easily fixed, new features easily added
Correctness
- All SPS specifications implemented properly

Chap 8

15. Why IPR are important

- IPR provides financial reward
Exp : artists earn income from their work.

- IPR gives control over usage
Exp : artists can prevent unauthorised use.

- IPR protects competitive advantages
Exp : An artist's unique style is their brand.

16. Type of Intellectual property (IPR)

Patent
- Exclusive right to commercialize an invention for a fixed period.

Copyright
- Legal right to commercially exploit original work and prevent unauthorized copying

Trademark 商标
- Trademarks are protected by intellectual property rights.

Trade Secret 商业秘密

17. Issues related to intellectual property (IPR)

Plagiarism
- Stealing someone else's ideas and claiming them as your own.
Exp : scenario + copy-pasting text without attribution

Reverse Engineering
- Analysing a product to discover its design and how it works.
Exp : scenario + dismantling a competitor's device to learn its secrets.

Open source code
- Software with publicly available source code that anyone can access, modify, and redistribute.
Exp : scenario + must check license terms before using.

Competitive Intelligence
- Gathering and analysing patent and market data about competitors.
Exp : scenario + help identify risks and opportunities.

Trademark infringement
- illegal use of another's trademark causing confusion about the true source of services.

18. Cybersquatting // Types 网络域名抢注
Identity theft
- Registering a domain that looks identical to a legitimate business to assume its online persona.

Name Jacking
- Creating fake websites or social media profiles using a famous person's real name.

Typosquatting
- Registering misspelled versions of popular brand domains.
Exp : "Googlo.com" , capitalises on typing errors.

Extra
PDPA / Four principle
General Principle

Disclosure Principle
- data may not be disclosed to third parties without consent

Data Integrity Principle

Access Principle